

Introduction

To use guessing and cracking in order to expose weak passwords is an important step for each penetration test. Finding a publicly-facing service in the network with a weakly set password can be enough to bypass the firewall and gain an insider view of the system or network. In this exercise, the password brute-forcing tool John the Ripper will be used in conjunction with cewl to create a wordlist. The wordlist will then be subjected to mutation, and with this modified wordlist, attempts will be made to gain access to a vulnerable web application. From there, the objective is to escalate privileges to obtain root access on the system.

Helpful tools

All the tools necessary for this exercise are preinstalled on Kali

- John The Ripper
- CeWL
- WPScan

Exercise 1: Enumeration and Initial Access

On your group's subnet, the machine for this exercise is IP: 10.10.XX.64. The first step of this challenge is to break into the administrator account of a web application.

Exercise 2: Gaining a Shell

The second step is to obtain a shell from the administration panel.

Exercise 3: Escalate Privileges

And the third step is to escalate the privileges to root privileges. Remember, the theme of this exercise sheet is password cracking. Here is a good resource to start with. <https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Linux%20-%20Privilege%20Escalation.md>

Hints

It is necessary for this exercise to write a custom mutation rule for John, as described in the lecture. We won't give you more explanation for now. We want you to try first and ask us when you feel stuck (Daniel Reti). Tell me what you have tried so far, and I will help you with further hints.

Report

Write a brief report including your solutions and your findings. Then, submit the report via Olat. You can find a $\text{\LaTeX}$ template on OLAT.